

Enterprise IAM & HR System Architecture

A Complete Draft Technical Proposal for Hybrid Deployment

Prepared For: Engineering & Leadership Team

Author: Technical Lead / Architect

Frameworks: Laravel, AWS Services, On-Premises Compute

Security Model: Hub-and-Spoke Identity, Cryptographic Separation, Hybrid RBAC/ABAC

Date: September 2026

Status: Draft Proposal for Review

1. Executive Summary

This proposal defines the comprehensive system architecture for a high-performance Human Resources (HR) ecosystem featuring localized directory capabilities seamlessly paired with a client-facing application tier. The focal point of this engineering initiative is the absolute separation of **Workforce Identities** (internal organizational employees) from **Customer Identities** (external service clients / CIAM).

By implementing a hybrid topography leveraging private on-premises infrastructure alongside AWS managed clouds, we capture maximum data residency compliance without relinquishing cloud-native flexibility. Fine-grained authorization logic combines structural Role-Based Access Control (RBAC) with runtime dynamic Attribute-Based Access Control (ABAC) variables containing structural attributes like branch limits and department codes.

2. Strategic Identity Plane Separation

Blending employee data with customer identity tables presents a severe systemic risk vector. We enforce a strict, zero-trust isolated identity framework separating internal and external credentials into non-communicating rings.

2.1 Workforce Identity System

Internal human resources profiles are anchored within a strict corporate security zone. Access paths utilize high-friction, device-attested, phishing-resistant Multi-Factor Authentication (MFA). Account lifecycles tightly couple to the internal HR directory engine for instant onboarding, structural updates, and immediate offboarding protocols.

2.2 Customer Identity & Access Management (CIAM)

External consumer clients navigate an elastic cloud registry via AWS Cognito. Security emphasis shifts to friction-optimized conversion mechanisms like social single sign-on (SSO), biometric passkeys, and progressive profiling schemas. The CIAM platform shares zero transactional databases or directory routes with the central corporate employee ledger.

3. Hybrid Infrastructure & Deployment Topology

Deploying our stack in a hybrid landscape splits computational duties rationally down boundaries of compliance, durability, and cost metrics:

Infrastructure Plane	Components Hosted	Strategic Rationale
----------------------	-------------------	---------------------

On-Premises Servers	Laravel HR Core Engine, Master Employee/Payroll DB, Storage Volumes	Guarantees local data residency controls and removes high cloud storage overheads.
AWS Cloud Infrastructure	AWS Cognito (CIAM Pools), Amazon SQS, Amazon SES Notification Engine	Leverages hyperscaler elasticity to offload unpredictable load spikes.

4. Core Laravel Architecture Code Design

To ground these principles in the development cycle, the Laravel implementation divides authentication paths natively.

4.1 Guard Configuration (`config/auth.php`)

Configuring discrete drivers establishes clean runtime isolation context boundaries between session-based workers and token-based customers.

```
// config/auth.php
return [
    'guards' => [
        'workforce' => [
            'driver' => 'session',
            'provider' => 'employees',
        ],
        'customer' => [
            'driver' => 'jwt',
            'provider' => 'customers',
        ],
    ],
    'providers' => [
        'employees' => [
            'driver' => 'eloquent',
            'model' => App\Models\Employee::class,
        ],
        'customers' => [
            'driver' => 'database',
            'table' => 'customer_identities',
        ],
    ],
];
```

4.2 Hybrid RBAC + ABAC Authorization Policy

Rather than experiencing 'role explosion' for distinct regional limits, access checks use static roles layered against tokenized structural attributes.

```
namespace App\Policies;

use App\Models\Employee;
use App\Models\ExpenseClaim;

class ExpenseClaimPolicy
{
    /**
     * Contextual enforcement combining structural RBAC and granular ABAC
     */
    public function approve(Employee $employee, ExpenseClaim $claim): bool
    {
        // 1. RBAC Validation: Structural organizational access right
        if (! $employee->hasRole('Manager')) {
            return false;
        }

        // 2. ABAC Attribute Boundary Validation: Dynamic checking
        if ($employee->department !== $claim->department || $employee->branch_id !== $claim->branch_id) {
            return false;
        }

        // 3. ABAC Limit Check: Mathematical constraint checks
        return $employee->approval_limit_usd >= $claim->amount_usd;
    }
}
```

5. Runtime Attribute-Based Security Payloads

When authentication succeeds, metadata attributes are tightly packed directly within structural web tokens (JWTs) or session properties. This completely bypasses heavy SQL join dependencies at routing levels.

```
{
  "sub": "emp_01JK897654",
  "name": "Alex Mercer",
  "roles": ["Manager"],
  "department": "Talent_Acquisition",
  "branch_id": "HQ-01",
  "approval_limit_usd": 25000,
  "iat": 1790067300,
  "exp": 1790070900
}
```

Architectural Impact: Edge reverse-proxies or API routers inspect claims instantly, terminating illicit requests before passing execution pipelines down to the primary core application engines.

6. Identity Governance and Life-Cycle Framework

Because critical transactional limits (e.g. *approval_limit_usd*) exist as properties inside identity claims, modification parameters are strictly constrained:

- **Read-Only Execution Envelopes:** Users are physically barred from self-modifying profile vectors.
- **Event-Driven Sync Channels:** Promotion or regional reassignment metrics automatically push mutations downward dynamically from secure administrative master logs.
- **Just-In-Time (JIT) Elevation Lifecycles:** Transient limit alterations require dual out-of-band management approval structures via programmatic queues (e.g., Slack/Teams webhook validations), automatically self-expiring after a fixed execution window.

This is for informational purposes only. For medical advice or diagnosis, consult a professional. AI responses may include mistakes.